SIMATS ENGINEERING
ASSESSMENT TOOL 3

COURSE NAME: Ethical Hacking **COURSE CODE: ITA1412**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Scenario-Based Assessment

Topic 1: Footprinting Tools – Conducting Competitive Intelligence

Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

Task: Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

Topic 2: DNS Zone Transfers

Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

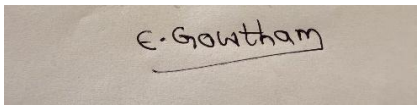
Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

Code of Conduct:

I Enamala Gowtham /192311190 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: 

RUBRICS FOR CALCULATION

Scenario Based Assessment

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

Q1. Footprinting Tools – Conducting Competitive Intelligence

Scenario: A cybersecurity consultant must conduct a passive security assessment of ABC Technologies without directly interacting with its servers.

1. Introduction

Footprinting is the process of collecting information about an organization, its domain, employees, technologies, and network infrastructure. In passive footprinting, publicly available sources are used without directly probing the target's servers. This helps identify potential security risks while minimizing the impact on the organization.

2. Tools used for footprinting

Information required	Tool	Purpose
Domain registration details	WHOIS Lookup	Identifies registrar, registration dates, and available registration information.
Employee email addresses	theHarvester	Collects publicly indexed email addresses from supported sources.
Technology stack	Wappalyzer or BuiltWith	Identifies publicly detectable web technologies and frameworks.
Public subdomains	Certificate Transparency logs and DNSDumpster	Helps discover publicly recorded certificates and subdomain information.

3. Application of each tool

a) WHOIS Lookup — Domain registration

WHOIS services help retrieve domain registration information, such as the registrar, creation date, expiry date, and name servers, when available.

Example command:

whois example.com

Replace example.com with the authorized assessment domain. Privacy protection may hide the registrant's personal information.

b) theHarvester — Employee email addresses

TheHarvester gathers publicly indexed email addresses and related information from supported search engines and data sources.

Example command:

theHarvester -d example.com -b crtsh

The results may reveal publicly indexed email addresses that could be targeted by phishing attacks. Use only permitted data sources and authorized assessment scope.

c) Wappalyzer or BuiltWith — Technology stack

These tools identify technologies used by a publicly accessible website, such as content management systems, JavaScript frameworks, web servers, and analytics tools.

For example, identifying an outdated framework can help an authorized security team investigate whether a known vulnerability may affect the application. Technology detection alone does not prove that a vulnerability exists.

d) Certificate Transparency and DNSDumpster — Subdomains

Certificate Transparency logs contain publicly recorded TLS certificate information. DNSDumpster provides DNS-related reconnaissance information and potential subdomain discoveries.

These sources may reveal hostnames such as mail.example.com, vpn.example.com, or portal.example.com. Such names are leads for further authorized assessment, not proof that a host is active or internally accessible.

4. How these tools help in competitive intelligence

These tools help the consultant understand the organization's public digital footprint without directly interacting with its servers.

- WHOIS identifies domain ownership and registration information.
- theHarvester identifies publicly indexed employee email addresses.
- Wappalyzer and BuiltWith reveal the technologies used by the website.
- Certificate Transparency and DNSDumpster reveal potential subdomains and publicly available DNS information.

5. Conclusion

Passive footprinting is an important first step in cybersecurity assessment. These tools help collect useful information, understand the organization's technology environment, and identify potential security weaknesses. The findings should be documented and validated during an authorized assessment.

Q2. DNS Zone Transfers

Scenario: During an authorized penetration test, the analyst suspects that the target organization's DNS server may allow unauthorized zone transfers.

1. Introduction

A DNS zone transfer is a process that copies DNS records from one DNS server to another, typically between primary and secondary DNS servers. It is commonly performed using AXFR (Full Zone Transfer). If a DNS server permits unauthorized zone transfers, an attacker may obtain a large amount of information about the organization's DNS infrastructure. Therefore, zone transfers should be restricted to authorized secondary servers.

2. Tools required

- dig — Queries DNS servers and tests zone-transfer permissions.
- nslookup — Performs DNS queries and helps identify DNS records.
- DNS server logs — Help administrators verify and investigate zone-transfer requests.

3. Procedure to verify a DNS zone transfer

Step 1: Identify the authoritative name servers.

Use the following command:

dig NS example.com

This displays the authoritative name servers for the domain.

Step 2: Test whether the server permits a zone transfer.

Run the following command against an authorized test domain and its authoritative server:

dig @ns1.example.com example.com AXFR

Here:

- dig is the DNS query utility.
- @ns1.example.com specifies the DNS server.
- example.com is the DNS zone being tested.
- AXFR requests a full zone transfer.

Step 3: Interpret the results.

- Transfer succeeds: The response contains a sequence of DNS records, potentially including the start and end of the zone.
- Transfer refused: The server denies the request, indicating that the transfer is not permitted for that requester.
- Timeout or connection failure: The result is inconclusive; it does not by itself prove that the server is securely configured.

4. How retrieved DNS records assist reconnaissance

If a zone transfer succeeds, the retrieved records may reveal:

DNS record	Information obtained

A / AAAA	IPv4 or IPv6 addresses associated with hostnames.
MX	Mail servers used by the domain.
NS	Authoritative name servers.
CNAME	Aliases that point to other hostnames.
TXT	Text records, which may include email-security policies and domain-verification data.
SRV	Services and their associated hostnames or ports.

For example, records for mail.example.com, vpn.example.com, or dev.example.com may reveal mail infrastructure, remote-access entry points, or development-related hostnames. A hostname alone does not establish that a system is internal or exposed to the public internet.

5. Security risks

An improperly configured zone transfer may:

1. Expose details about the organization's network naming structure.
2. Reveal mail servers and service-related hostnames.
3. Help attackers identify potentially sensitive systems.
4. Make subsequent targeted reconnaissance easier.

6. Countermeasures

- Restrict AXFR requests to explicitly authorized secondary DNS servers.
- Configure access controls and use TSIG authentication where supported.
- Review DNS server configuration and logs regularly.
- Separate internal and external DNS information where appropriate.
- Avoid exposing sensitive hostnames unnecessarily.
- Retest the configuration after applying fixes.

7. Conclusion

The dig command with the AXFR option is a suitable method for checking DNS zone-transfer permissions during an authorized penetration test. A successful unauthorized transfer indicates a configuration weakness that should be corrected by restricting transfers to trusted servers and monitoring DNS activity.

Q3. Social Engineering Attacks and Countermeasures

Scenario: Employees receive an email claiming to be from the IT department and requesting that they verify their login credentials through a link because of an urgent security update.

1. Identify the attack

The described attack is phishing, a type of social engineering attack. In phishing, an attacker impersonates a trusted person or organization to trick victims into revealing confidential information, clicking malicious links, or performing unsafe actions.

The email uses two common psychological techniques:

- Authority: It pretends to come from the IT department.
- Urgency: It claims that immediate action is required because of a security update.

These techniques pressure employees into acting without verifying the message.

2. How the attack works

Step 1: Fake email

An attacker impersonates the IT department.

Step 2: Urgent request

The employee is asked to verify credentials through a link.

Step 3: Credential theft attempt

A fraudulent login page may capture the employee's username and password.

Step 4: Potential account compromise

The attacker may attempt to misuse stolen credentials to access organizational resources.

3. Countermeasures employees should follow

a) Verify the sender's identity

Check the complete sender email address and domain. Do not trust a message merely because it displays the IT department's name.

b) Avoid clicking suspicious links

Do not open unexpected login links or attachments. Instead, access the organization's official portal using a known bookmark or manually entered address.

c) Never disclose passwords through email links

Employees should not enter credentials into a page reached through an unexpected message. Legitimate security procedures should be verified independently.

d) Confirm urgent requests independently

Contact the IT department using a known official phone number, help desk, or internal communication channel. Do not use contact details supplied only in the suspicious email.

e) Report the email

Use the organization's phishing-reporting process or contact the security team. The team can investigate the message and warn other employees.

f) Enable multifactor authentication (MFA)

MFA adds an additional authentication requirement beyond a password. Phishing-resistant MFA, such as passkeys or security keys, provides stronger protection against credential phishing.

g) Conduct employee awareness training

Regular training helps employees recognize suspicious links, unexpected credential requests, misleading sender addresses, and messages designed to create panic.

h) Apply technical email security controls

Organizations should use email filtering, spam detection, domain authentication mechanisms such as SPF, DKIM, and DMARC, and monitoring for suspicious sign-in activity.

4. How these actions prevent credential theft

Countermeasure	How it helps
Sender verification	Helps identify impersonation attempts.
Avoiding suspicious links	Reduces the chance of reaching fraudulent login pages.
Independent verification	Confirms whether the request is legitimate.
Phishing reporting	Allows security teams to investigate and protect other employees.
MFA and passkeys	Reduce the risk of unauthorized access using stolen passwords.
Employee training	Improves recognition of social engineering techniques.
Email filtering	Helps detect and block suspicious messages before delivery.

5. What should an employee do after clicking the link?

If an employee has already entered credentials, they should immediately contact the IT/security team, change the affected password through the official portal, revoke active sessions where possible, and follow the organization's incident-response procedure. The security team should review account activity and assess whether other systems may be affected.

6. Conclusion

The scenario describes a phishing attack that uses impersonation and urgency to obtain employee credentials. Employees can reduce the risk by verifying requests independently, avoiding suspicious links, reporting phishing emails, and using strong authentication methods. A combination of employee awareness and technical security controls provides effective protection against credential theft.